

Security Management

Emergency, Crisis, Pandemics

IT-Sicherheit | 25.03.2026

Gerald Dißauer | Lecturer

A-SIT Secure Information Technology Center Austria

www.dhbw-stuttgart.de

Agenda

Introduction

Basic Principles of Crisis Management & Emergency Handling

Crisis & Emergency Handling | Management Techniques

Practical Experiences from Conducted Projects

Discussions & Summary

Agenda

Introduction

Basic Principles of Crisis Management & Emergency Handling

Crisis & Emergency Handling | Management Techniques

Practical Experiences from Conducted Projects

Discussions & Summary

LECTURE OBJECTIVE

WHY DO WE NEED BUSINESS CONTINUITY?

Corporations and organizations (e.g., authorities, NGOs, NPOs)

are exposed to risks

such that the services or business processes

provided to customers and other contractual partners

may no longer be able to be provided to the agreed extent

due to occurring events which disrupt the business.

KEYWORDS



RECENT OBSERVATIONS FROM INDUSTRY DOING THE BASICS RIGHT

08/2017 | “While they may not always feel glamorous, strong **managerial processes** really **matter**. It’s great that **Google made its public** [...]”¹

2018 | “More and more organizations are accepting the fact that, despite their best efforts, **security breaches are unavoidable**. [...] It’s not a question IF your network will be breached, **the only question is WHEN**”²

¹ cf. (Sadun, 2017)

² cf. (Gemalto NV., 2018, p. 2, p. 16)

RECENT OBSERVATIONS FROM INDUSTRY | cont'd

DOING THE BASICS RIGHT

05/2018 | *"I've been getting some weird press calls from reporters wanting to know if this demonstrates that e-mail encryption is impossible. No, this just demonstrates that **programmers are human and vulnerabilities are inevitable**. PGP¹ almost certainly has **fewer bugs than your average piece of software, but it's not bug free**."*²

09/2018 | *"No matter how much **resources** you **spend** for **security** systems, you become **not** completely **protected** against hacker **attacks**."*³

09/2019 | *"Technology alone can not protect a network."*⁴

¹ PGP – Pretty Good Privacy

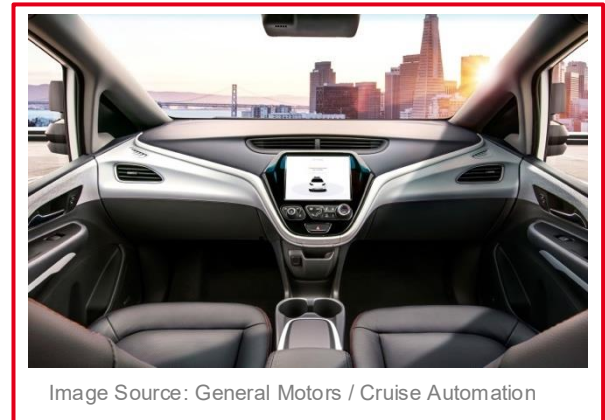
² cf. (Schneier, 2018)

³ cf. (Bochman, 2018, p. 38); (G. Dißauer, Trans.) (Original work published 09/2018)

⁴ cf. (Winnefield, Kirchhoff, Upton, 2019, p. 21); (G. Dißauer, Trans.) (Original work published 02/2019)

WHAT ARE PRACTICAL APPLICATION SCENARIOS? SECURITY MANAGEMENT IS NEARLY EVERYWHERE

- Automotive security
- Aerospace systems
- Payment systems
- Electronic identities
- Healthcare Information Systems
- Internet of Things (*IoT*)



„Information are valuable assets and organizations are subjects to attacks“

WHICH ORGANIZATIONS ARE ADDRESSED?

SECURITY MANAGEMENT AND BUSINESS CONTINUITY

- Every organization
 - Every corporation
 - Every company
 - Every authority
- } If computer systems are operated

A lot of organizations ignore security management nowadays¹

¹ Annotation: Most of them do, because security management does not provide direct value such as increasing numbers of sales or similar.

SELECTED EXAMPLES OF CYBER ATTACKS

EXAMPLES OF AFFECTED ORGANIZATIONS

- **Yahoo (2013)** impact ca. 3B users – real names, email, personal data, phone
- **Marriott (2014)** impact ca. 500M users compromised credit card data
- **eBay (2014)** impact ca. 145M users personal data compromised
- **Uber Technologies (2016)** impact ca. 57M users personal data compromised
- **Wendy's (2016)** impact ca. 40M credit card data compromised (> 1.000 restaurants)
- [...]

WHAT DO WE WANT TO ACHIEVE?

PROTECTING YOURSELF AND YOUR ORGANIZATION

4 main motives consolidated

- (1) Ensure the uninterrupted operation of relevant business processes
- (2) Ensure the operation even in critical situations such as emergencies and Crisis
- (3) Minimize impacts of emergencies and Crisis s.t. the business keeps alive
(*e.g., minimal activities to run the business*)
- (4) Business continuity based on recognized **international standards**

4 SELECTED REFERENCE STANDARDS INTERNATIONALLY RECOGNIZED

- **BSI¹ 100-4** „*Business Continuity Management*“ (detailed)
- **ISO² 27031** „*Information technology — Security techniques — Guidelines for information and communication technology readiness for business continuity*“ (detailed but focus on information security and IT)
- **ISO 22301** „*Business Continuity Management*“ (more generic than the above mentioned but an organization can be certified against it)
- **NIST³ SP⁴ 800-34** Contingency Planning Guide for Federal Information Systems

Differences in above mentioned standards need to be considered

¹ BSI – Bundesamt für Sicherheit in der Informationstechnik

² ISO – International Organization for Standardization

³ NIST – National Institute of Standards and Technology

⁴ SP – Special Publication

OTHER REFERENCE STANDARDS FOR INFORMATION

- ANAO Business Continuity Management
- ASIS SPC.1-2009
- BS 25999
- Financial Service Authority BCM Practice Guide
- Good Practice Guidelines (*GPG*)
- ISO/PAS 22399
- NFPA 1600
- NISCC Telecommunications Resilience

Agenda

Introduction

Basic Principles of Crisis Management & Emergency Handling

Crisis & Emergency Handling | Management Techniques

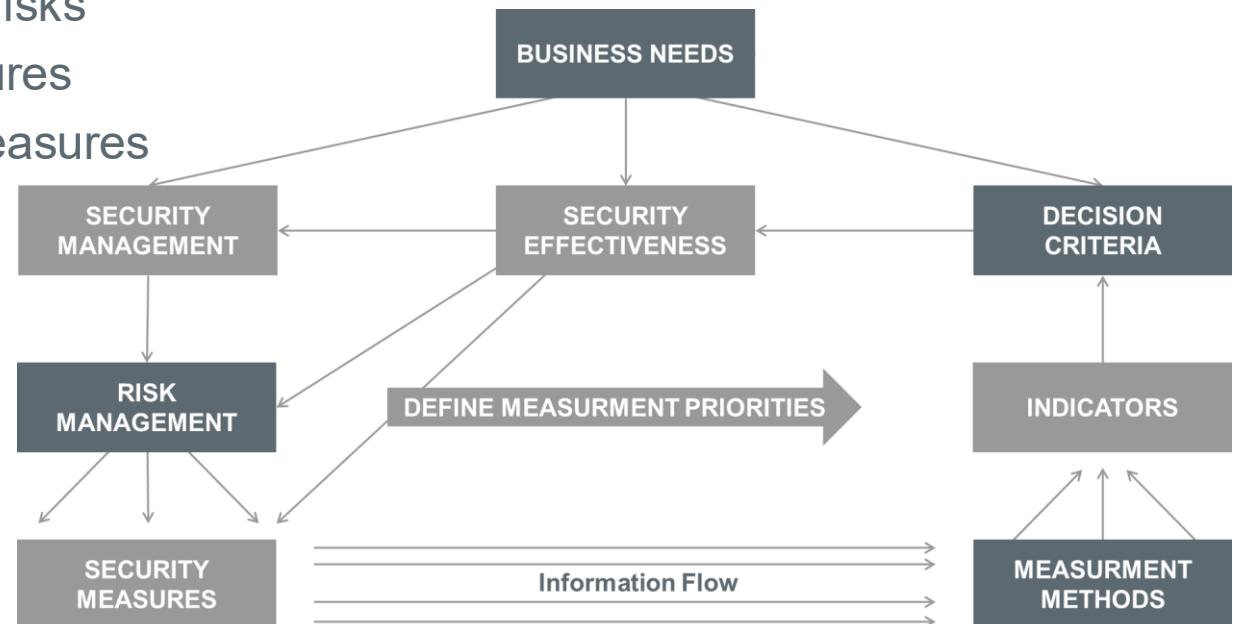
Practical Experiences from Conducted Projects

Discussions & Summary

ISO 27001 AND BUSINESS CONTINUITY

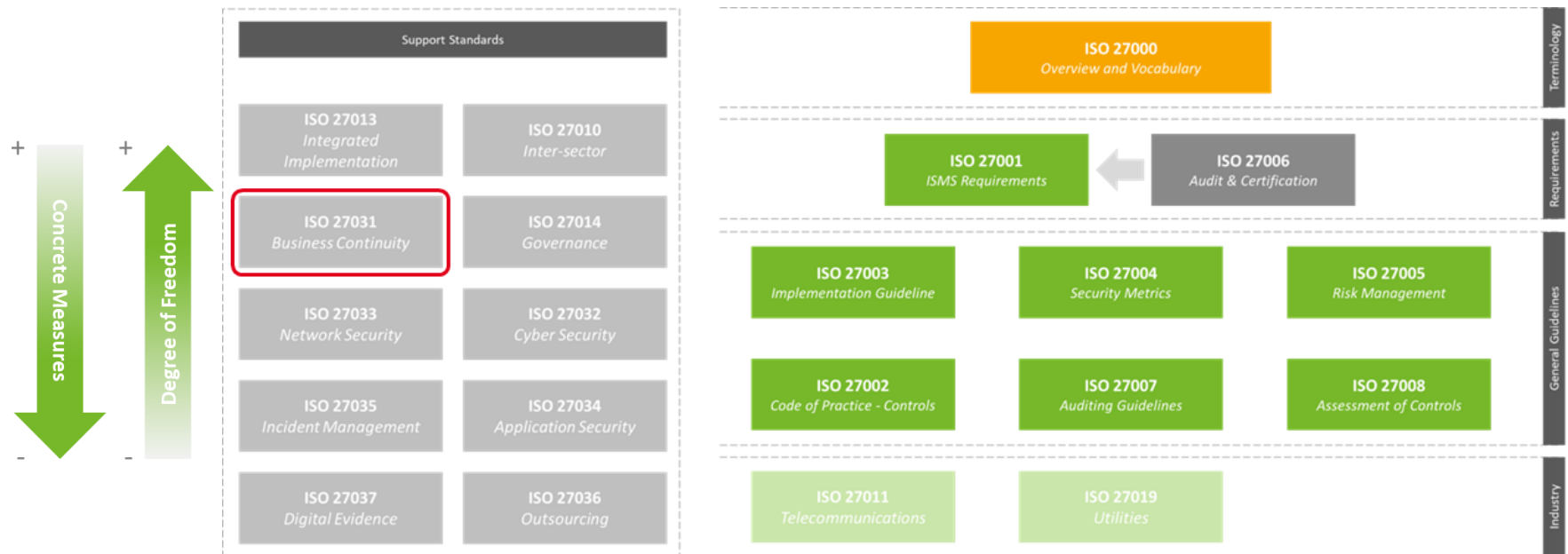
SECURITY MANAGEMENT BIG PICTURE IN CONJUNCTION WITH ISO 27001 and 27004

- Risk-based approach
- Assess and evaluate risks
- Derive security measures
- Decide on security measures



Own figure based on ISO/IEC 27004

WHAT IS THE STRUCTURE OF THE ISO/IEC 27001 FAMILY? THE CONTEXT FOR BUSINESS CONTINUITY



Own figure based on ISO/IEC 27001

GENERAL PROCESS FLOW

BUSINESS CONTINUITY

Business continuity is the ability to maintain continuous operations under emergencies, crisis, and/or disasters uncertain circumstances

8 proces steps

- Plan (*ensure survival of an organization under adverse changes*)
- Assess Risk (*identify threats and evaluate risks*)
- Mitigate Risk (*handle risks – not only mitigation!*)
- Prepare Security Controls (*install controls prepare plans*)
- Disaster Recovery (*focus on extreme business interruptions*)
- Business Recovery (*decide what to recover when to what extent*)
- Testing, Audit, Training (*identify weaknesses and conduct training*)
- Maintain (*derive improvement measures and install them*)



Own figure

ISO/IEC 27001 | ANNEX A

BUSINESS CONTINUITY FOCUS

- 27001 (*internationally recognized family of standards*)
- Only 27001 certifiable
- Annex A
- More details are given in 27002

Reference control objectives and controls

14 CATEGORIES OF REFERENCE CONTROL OBJECTIVES

1 REFERENCE CONTROL OBJECTIVE FOR BCM

- A.5 Information security policies
- A.6 Organisation of information security
- A.7 Human resource security
- A.8 Asset management
- A.9 Access control
- A.10 Cryptography
- A.11. Physical and environmental security
- A.12 Operations security
- A.13 Communications security
- A.14 System acquisition, development, and maintenance
- A.15 Supplier relationships
- A.16 Information security incident management
- A.17 Information security aspects of business continuity management**
- A.18 Compliance

ISO/IEC 27001 ANNEX A 17

INFORMATION SECURITY ASPECTS OF BCM

A 17.1 Information security continuity

A.17.1.1 Planning Information Security Continuity

A.17.1.2 Implementing Information Security Continuity

A.17.1.3 Verify, Review & Evaluate Information Security Continuity

A.17.2 Redundancies

A.17.2.1 Availability of Information Processing Facilities

SELECTED ASSETS TO CONSIDER AMONG HUMAN BEINGS

- Architecture (*e.g., Organization, programs, systems, applications, components, networks*)
- Network infrastructure (*e.g., redundancies physical, logical, VPN, and consider risk profiles*)
- Workspace infrastructure (*minimum workstations/notebooks by location*)
- Server infrastructure (*e.g., which server/data need to be available/recovered*)
- Database infrastructure (*e.g., which database(s) need to be recovered*)
- Mobile infrastructure services (*e.g., Smartphones, Tablets, Notebooks*)
- Network drives and files stored (*e.g., accessible via VPN*)
- [...]

SELECTED THREATS TO CONSIDER BUT WHAT ARE EMERGENCIES, Crisis, AND DISASTERS?

- Imperfect software products (e.g., ***Failure*** of components)
- Crashes of operating systems
- Application / app crashes
- Operational failures
- Network failures
- Data center problems
- External connection problems
- **Emergencies, Crisis, disasters**

„Define emergencies, Crisis, and disasters“
But how?

IMPERFECT SOFTWARE PRODUCTS

FAILURE, FAULT, ERROR, VULNERABILITY

The complexity of computer systems increases (*e.g., heterogeneous technology, interconnection, large-scale*) and a lot of complex computer systems are not free from deficits

Deficits of software products

- **Failure**

(a deviation of a software product w.r.t. its required functions in required quality specified in functional and non-functional requirements – an externally observable reliability concept e.g. by end-user)

- **Fault**

(a failure has its origin in a fault of the software product e.g. an incorrect step, process, or definition in a software product – an internally observable reliability concept; alternatively “bug” or “defect”)

Heads up: Fault masking is the presence, when one or more defects hide other defect(s)

- **Error**

(reason for the presence of a fault that was caused by e.g. programmer, requirements engineer)

- **Vulnerabilities**

(i.e., particular errors that can be exploited by an adversary to gain)

FAILURE OF A SYSTEM IN IT OPERATIONS

SELECTED EXAMPLE AND SUGGESTED SOLUTION

The scenario

A critical IT server failiure happens and an enduser observes that a web service is no longer accessible via the internet.

Suggested solution

A failover mechanism with at least one backup server should be planned and set up to immediately take over operations.

BUSINESS CONTINUITY

ISO 27031 Business Continuity Management IN CONJUNCTION WITH ISO 27001

- Suggests framework (*consider 7 relevant corner stones*)
- Includes performance criteria, design, and implementation
- Measurable ICT continuity



2 main objectives

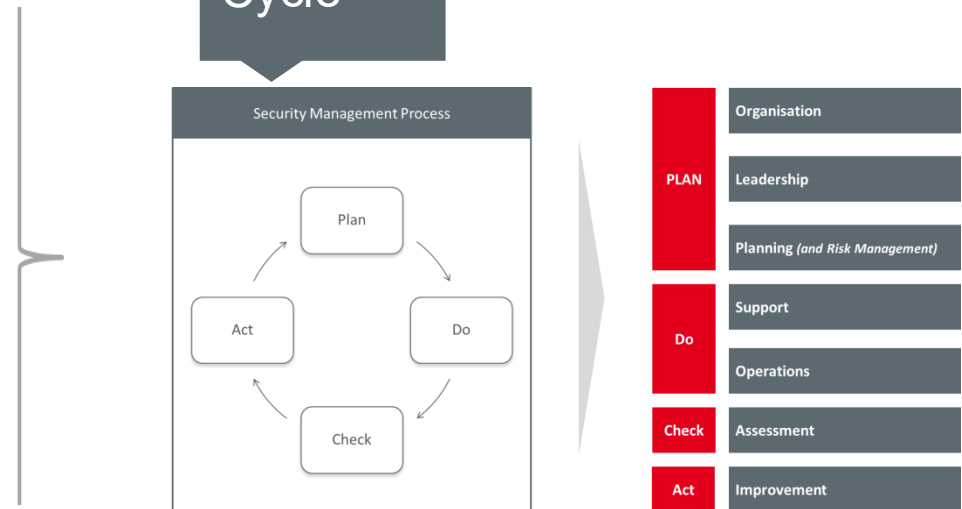
- (1) Preparing your organization's ICT, business processes, and people, against (*unforeseeable*) events that may change the risk environment and impact both ICT and business continuity
- (2) Allocate resources among business continuity, disaster recovery, emergency response and ICT security incident response and management activities

SOME OBSERVATIONS IN TERMS OF BUSINESS CONTINUITY PROCESSES, MANAGEMENT, PRIORITIZATIONS, PREVENT

- **Critical processes.** BCM ensure the continuity of critical processes for organizations, which are the very core to the business under a minimum acceptable level
- **Iterative management process.** BCM is an iterative management process – not a single one-off project. BCM is obsolete if not maintained, operated, improved or tested.
- **Prioritizations.** BCM activities should be prioritised with major attention towards critical business processes
- **Prevention and Impact reduction.** BCM covers both the prevention of emergencies/disasters/disruptions and reducing impacts to businesses in case of an emergency/disaster/disruption. Therefore: preventive, repressive and corrective

WHAT ARE 7 CORNER STONES OF BUSINESS CONTINUITY? CONJUNCTION TO PDCA-CYCLE

- Context (*of the organization*)
- Leadership
- Planning (*and risk management*)
- Support
- Operations
- Assessment
- Improvement



¹ Annotation: The PDCA cycle is also called Deming cycle

BUSINESS CONTINUITY IN CONJUNCTION TO PDCA CYCLE

- **Context.** Conduct self-assessment, classify the organization, clarify objectives of stakeholders, document it, derive scope/context (*i.e., sometimes not all units require BC*)
- **Leadership.** C-level commits to BCM, define responsibilities, distinguish between pro-active (*i.e., prepare; analysis, communication, plans, KPIs¹*), and re-active tasks (*i.e., act if something happens;*),
- **Planning.** Process-oriented, conduct project, risk assessment,

¹ KPIs – Key Performance Indicators

BUSINESS CONTINUITY IN CONJUNCTION TO PDCA CYCLE | cont'd

- **Support.** Address requirement and constraints, gather and allocate resources (*install and operate/maintain BCM*), focus on human beings, **documentation**
- **Operations.** Conduct Business Impact Analysis (*BIA*), analyze value chain, monitor KPIs¹, perform risk analysis, deal with emergencies and Crisis, pro-actively, and re-actively
- **Assessment.** Investigate BCM, processes, documentation, reports, test results, conduct management review, conduct internal and external audit
- **Improvement.** Integrate observations from tests, evaluations, audits, reviews and new know how to improve the BCM and the relevant processes

7 PILLARS OF OPERATIONS UNDER BCM

CONSOLIDATED WHAT TO DO

- (1) Business Impact Analysis (*BIA*) (*including **BIA analysis reports***)
- (2) Risk analysis
- (3) Business Continuity Strategy
- (4) Emergency Planning Concepts
- (5) Implementation of emergency and Crisis concepts
- (6) Handling of emergencies and Crisis
- (7) Tests and exercises

BUSINESS IMPACT ANALYSIS REPORT

SUGGESTION OF A BASIC STRUCTURE

Feasible Structure

- Titlepage (*classification, title, owner, history*)
- Introduction
- Process model of the BIA
- Business processes
- Context of assessed organizational units
- Evaluation of investigated business processes (*e.g., includes **KPIs***)
- Overview of critical processes (*e.g., list and matrix to face business process and IT systems*)

BUSINESS CONTINUITY KPI SELECTED EXAMPLES

- **Recovery time objective (RTO)**
Target level duration time in which business processes (and corresponding IT processes) should be recovered / restored after disruption
Short: „*Time from failure to recovery*“
- **Recovery point objective (RPO)**
Age of data that should be recovered in case of disruption
Short: „*Time how much data loss can be accepted*“

One can also use Key Risk Indicators and/or Key Goal Indicators

KPI, KGI, AND KRI

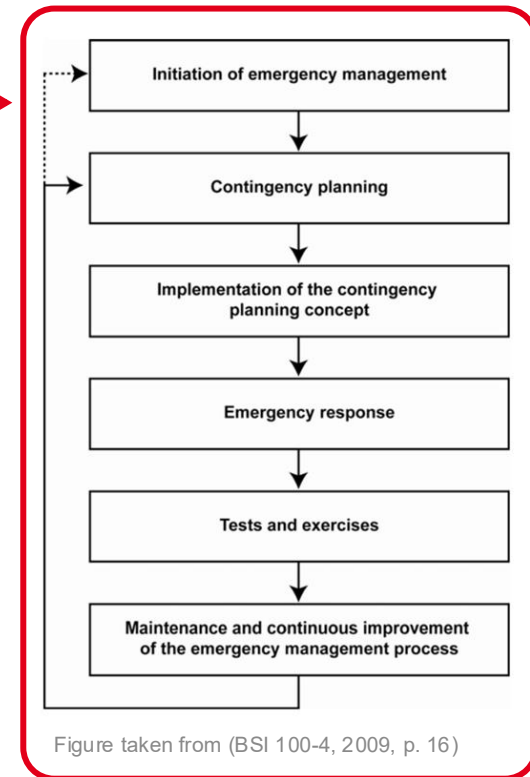
WHAT IS THE DIFFERENCE?

- **KGI** forward looking indicator (*e.g., # of hired IT specialists, targetet # of IT risk, # of standards used, # of standardized processes, # of processes with maturity level X*)
- **KPI** effectively achieving business objectives indicator ()
- **KRI** backward looking indicator (*e.g., #of cyber attacks, #of vulnerabilities, #of incidents, # of process failures*)

BSI 100-4 BUSINESS CONTINUITY

- **Emergency management process**
- Determine general conditions
- Derive contingency figures (*e.g., IT infrastructure*)
- Create concept and implement it
- Create plan for emergency response
- Perform tests to evaluate and improve measures
- Improve measures

Deal with incidents



4 CATEGORIES OF INCIDENTS

BSI 100-4

- (1) **Malfunction**
Low damage. A situation where processes or resources do not work as intended, usually by themselves and can be repaired by means of daily measures (*e.g. plans*) integrated into normal business operations. Limited in time and more predictable
- (2) **Emergency**
High to very high damage. An event where processes or resources do not work as intended. Cannot be handled in daily operations, the fulfillment of SLAs is detracted or impossible and emergencies are hard to predict. Requires business continuity response.
- (3) **Crisis**
A situation deviating from the normal state, which despite preventive measures of the organization are installed and it can occur at any time and can not be mastered with the normal (1) organizational and (2) operational measures. Invokes Crisis management.
- (4) **Disaster**
Large-scale damage. It is difficult to restrict locally and chronologically and it has or can have wide-ranging effects on people, assets, and property. The existence of organizations, people or health are at risk. Invokes disaster recovery management.

Agenda

Introduction

Basic Principles of Crisis Management & Emergency Handling

Crisis & Emergency Handling | Management Techniques

Practical Experiences from Conducted Projects

Discussions & Summary

CRISIS MANAGER IN THE FOCUS

SEVERAL SCENARIOS DIFFERENT Crisis MANAGERS

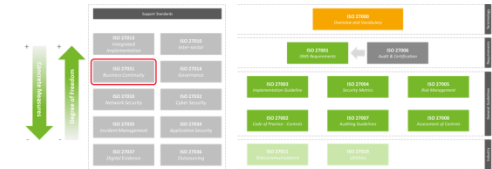
- Often talked about
- Very often forgotten
- Why different Crisis scenarios? To install targeted Crisis manager (*e.g., strategic – C-level or corporate communications, business unit managers for e.g., **pandemics***)

Install a Crisis manager

CRISIS MANAGEMENT AND EMERGENCY HANDLING REQUIRED PLANS

Documented processes, procedures and techniques

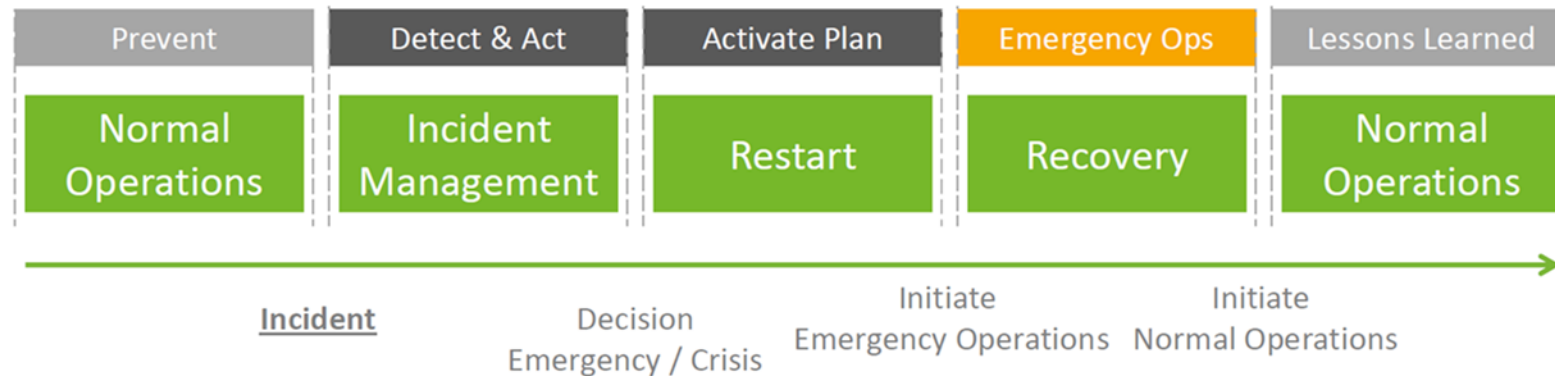
- Business continuity policy (*or plan, policy, guideline*)
- **Crisis management handbook** (*or policy, guideline*)
- **Emergency handbook** (*or plan, policy, guideline*)



Have a look at emergencies

EMERGENCY MANAGEMENT

EMERGENCY MANAGEMENT PROCESS STEPS CONSOLIDATED VIEW



Own figure

EMERGENCY HANDBOOK

SELECTED EXAMPLE

Document title page suggestions

- Document title
- Document owner
- Document reviewer
- Document approver
- Date
- Version history
- Document class (*e.g., confidential, secret, top secret under InfoSig BGBI. II Nr. 548/2003*)

EMERGENCY HANDBOOK

SELECTED EXAMPLE | cont'd

Document details to be addressed

- Stakeholders (*e.g., corporation internal, authorities*)
- Electronically available at location (*e.g., intranet*)
- Physically available at location (*e.g., printed*)
- Document reviews and assessment (*e.g., bi-annually, regularly, ad-hoc*)

EMERGENCY HANDBOOK

SELECTED EXAMPLE | cont'd

Selected references

- Information security strategy
- Risk management policy
- Business continuity management (*BCM*) policy
- Business impact analysis (*BIA*)
- Crisis management handbook
- IT service management
- [...]

EMERGENCY HANDBOOK

CONTENT AND OVERVIEW

- (1) Introduction
- (2) Scope and Objectives
- (3) Organizational Roles (*e.g. CTO, CISO, CSO, CRO, emergency manager, deputy*)
- (4) Emergency Process and Emergency Measures
- (5) Contacts and communication channels (*e.g., internal, external, phone, mobile, SMS, email, distribution list*)
- (6) Business processes and IT
- (7) Emergency workspace (*e.g., for business processes, secondary site, home office, smart devices*)
- (8) Internal and external suppliers
- (9) Ressources and premises
- (10) References

CRISIS MANAGEMENT

CRISIS MANAGEMENT HANDBOOK

SELECTED EXAMPLE

Document title page suggestions

- Document title
- Document owner
- Document reviewer
- Document approver
- Date
- Version history
- Document class (*e.g., confidential, secret, top secret under InfoSig BGBI. II Nr. 548/2003*)

CRISIS MANAGEMENT HANDBOOK

SELECTED EXAMPLE | cont'd

Document details

- Stakeholders (*e.g., corporation internal, authorities*)
- Electronically available at location (*e.g., intranet*)
- Physically available at location (*e.g., printed*)
- Document reviews and assessment (*e.g., bi-annually, regularly, ad-hoc*)

CRISIS MANAGEMENT HANDBOOK

SELECTED EXAMPLE | cont'd

Selected references

- Emergency handbook
- Business continuity policy
- Internal and external contacts (*or contact lists*)
- Information security strategy
- Risk management policy
- Business continuity management (*BCM*) policy
- Business impact analysis (*BIA*)
- [...]

CRISIS MANAGEMENT HANDBOOK CONTENT

SELECTED EXAMPLE

- (1) Introduction
- (2) Crisis prevention
- (3) Crisis management
- (4) Crisis communications
- (5) Crisis scenarios (*e.g., strategic, tactical, operational, environmental, law, building, human beings, technical, ressources*)
- (6) References

Agenda

Introduction

Basic Principles of Crisis Management & Emergency Handling

Crisis & Emergency Handling | Management Techniques

Practical Experiences from Conducted Projects

Discussions & Summary

SOME OBSERVATIONS IN TERMS OF BCM PROJECT EXPERIENCES

- **Critical processes.** Very hard for organizations to identify the “very core” because *“everything what we do is necessary”*
- **Iterative management process.** Very often one-off project and inadequate documentation
- **Prioritizations.** Often stressed, often talked about, not very often executed
- **Prevention and Impact reduction.** Like a fire insurance, until nothing happens, not necessary – but if the fire burns, it is too late to sign up a contract
- **Detect & recover.** Modern way of dealing with incidents “detect & recover”

Cyber attacks happen, the only question is – WHEN

SOME OBSERVATIONS IN TERMS OF BCM PROJECT EXPERIENCES | cont'd

- *“We are too small to implement business continuity management”*
- *“We are too big to implement business continuity management”*
- *“We are not target of cyber attacks”*
- *“We do not have such problems, we are too big”*
- *“We do not have such problems, because we conducted 1 project several years ago to create documentation”*
- *“Pandemics are not realistic, such scenarios do not happen”*
- *“We can handle emergencies ad-hoc”*

PANDEMICS

CLASSIFICATION AND CONSIDERATIONS

- Take under consideration staff shortage
- Take into account redundant staff planning
- Consider to locate staff at redundant locations (*e.g., backup location, secondary site*)
- Make such plans accessible both electronically and physically to authorized personnell

**Pandemics can be classified as Crisis scenarios
in terms of human beings**

PANDEMICS AND CYBER THREATS

RECENT OBSERVATIONS

- COVID-19 („Corona“) capitalized for cyber attacks
- Home office as increasing risk for organizations (e.g., *authorities, companies*) exploited to attack companies in a targeted manner (e.g., *TrickBot trojan to address attacks against RDP¹*)
- Fake VPN solutions as a rising threat
- Increasing number of phishing emails in terms of COVID-19
- Targeted ransomware attacks (e.g., „Maze“ *Ransomware against Cognizant Corp.*)
- Security measures in home office not the same like at premises
- Internet outages at home likely due to capacity overload
- Public authorities directly affected by targeted attacks

¹ RDP – Remote Desktop Protocol

HOW CAN WE CONSIDER PANDEMICS A PRIORI?

WHAT CAN BE TAKEN INTO ACCOUNT

- Significant staff shortage taken into account
- Install targeted Crisis manager (*e.g., HR role including deputy*)
- Create Crisis scenarios (*description, threat, communication, detect situation, decision making, create protocol of Crisis situation, install **Crisis team**, update information, derive objectives initiate Crisis plan e.g., for pandemic, identify solved crisis, close Crisis management*)
- Take pandemic plans into account (*e.g., City of Vienna and others*)
- Preventive measures (*e.g., scenarios with or without vaccine,)*
- Reactive measures (*e.g., quarantine, isolation, medical counter measures, vaccines, resources*)
- Exercises and tests (*of the plans and the measures*)

HOW CAN WE COMPOSE A CRISIS TEAM? SUGGESTED TEAM MEMBERS

- Crisis manager (*and deputy*)
- PR officer
- C-Level representative
- Affected organizational units
- Communications officer
- Contacts to business partners
- Process manager
- IT manager (*e.g., CTO, product owner, service manager*)
- External advisors
- Representatives of authorities
- [...]

Agenda

Introduction

Basic Principles of Crisis Management & Emergency Handling

Crisis & Emergency Handling | Management Techniques

Practical Experiences from Conducted Projects

Discussions & Summary

SUMMARY

COVERED TOPICS

- **Clarified business continuity fundamentals** in terms of ISO 27001
- **Explored emergency** management and **Crisis management**
- **Demonstrated** details about **examples** in terms of **Crisis** and **emergency handbooks**
- **Showed practically applicable measures** to counter **pandemics**
- **Discussed practical experiences** from conducted projects w.r.t. business continuity, Crisis management and emergency management in conjunction with ISO 27001
- **Showed** business continuity **management process**

